



2026 SETE

HILTON, SYDNEY
27 - 30 APRIL 2026

Systems Engineering |
Test & Evaluation Conference 2026

ADDING 'SUPERPOWERS' TO SYSTEMS ENGINEERING

Bruce Large CPEng RPEQ



**Applying the ISA/IEC 62443
standards series to your Projects**



Systems Engineering
Society of Australia



Bruce Large CPEng RPEQ

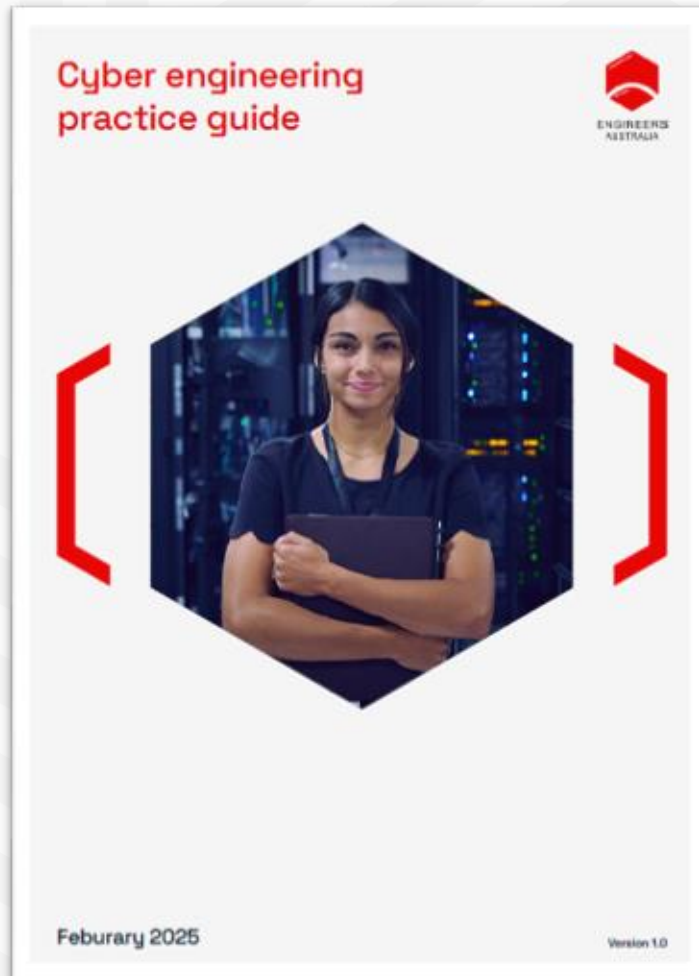


- Bruce is the Founder and Principal Cyber Security Architect at BLARGE
- Bruce is a Chartered Professional Engineer (CPEng) in Information, Telecommunications and Electronics Engineering (ITEE) and Cyber Engineering and a Registered Professional Engineer of Queensland (RPEQ) in IT&E
- Bruce has over 15 years experience working with IT and Operational Technology (OT) in Network, Telecommunications and System Engineering roles
- Bruce has worked in Electricity Generation & Transmission, Railway, Aviation, Emergency Services and Consulting industries
- Bruce is a Foundation Chartered SABSA Architect (SCF), holds the Global Industrial Cyber Security Professional (GICSP), GIAC Response and Industrial Defense (GRID) certificate, GIAC Cyber Threat Intelligence (GCTI), GIAC Security Operations Manager (GSOM), an ISA/IEC 62443 Cybersecurity Expert, and has attended Industrial Control Systems (ICS) Cyber Security training at QUT
- Bruce graduated with a Bachelor of Engineering (Telecommunications) First Class Honours and a Master of Business (Applied Finance) with Distinction from QUT



EA Cyber Engineering Area of Practice

The area of practice includes the below practice elements



Threat modelling
and risk analysis

Security models
and standards

Human factors

Computer
networking

Security
architectures

Cyber laws and
regulations

System, data
protection and
cryptographic
systems

Advanced
mathematical
concepts

Infrastructure
security

Authentication,
authorisation and
accountability

Systems
engineering

Software
engineering

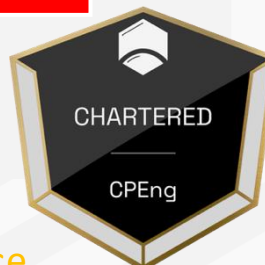
Cyber system
design

Supply chain
management

Business continuity
and incident
management

Emerging
technologies

Vulnerability
assessment and
penetration testing





Why this presentation?

Agenda

1. Overview of the ISA/IEC 62443 Standard Series
2. Applying 62443 to your Project using Part 3-2 and Part 3-3
3. Building secure Components using Part 4-1 and Part 4-2
4. Aligning ISA/IEC 62443 with the System Engineering Lifecycle
5. Further Resources
6. Q&A

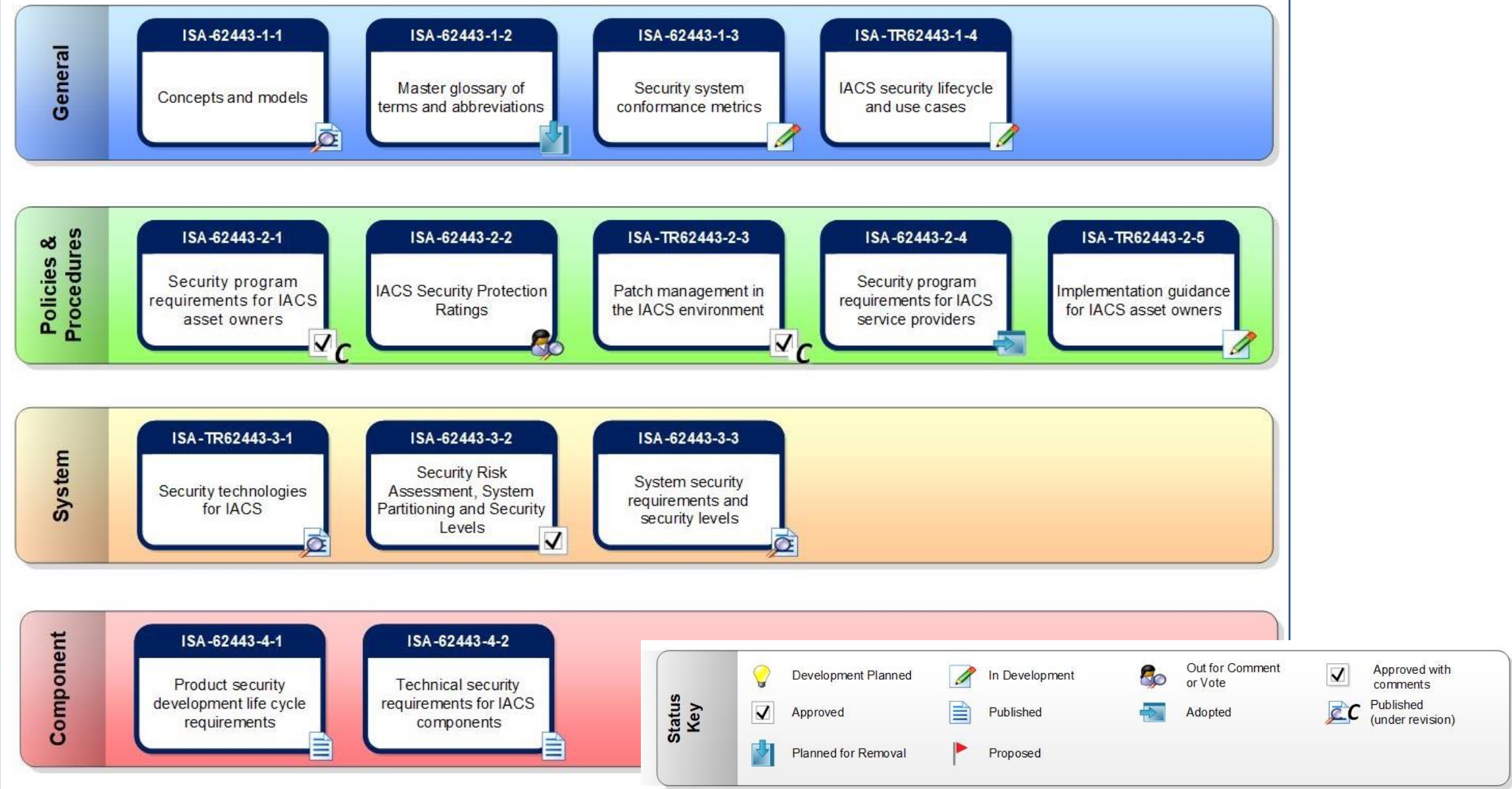


Overview of the ISA/IEC 62443 Standards Series

Overview of ISA/IEC 62443

- ISA/IEC 62443 is a Framework of Cyber Security Standards for Industrial Automation and Control Systems (IACS)
- ISA 99 is the Working group and the standards were originally published with ANSI as ISA 99 but are now published in partnership with the IEC and are designated ISA/IEC 62443
- You might see ISA 95 – Enterprise-Control System Integration – it is based on the Purdue Model but it is separate to ISA 62443
- ISA 62443 is referenced by the NIST Cyber Security Framework but only 2 of the 14 publications referenced (Part 2-1 and Part 3-3)

62443 Framework on a page



Hierarchy and Lifecycle View

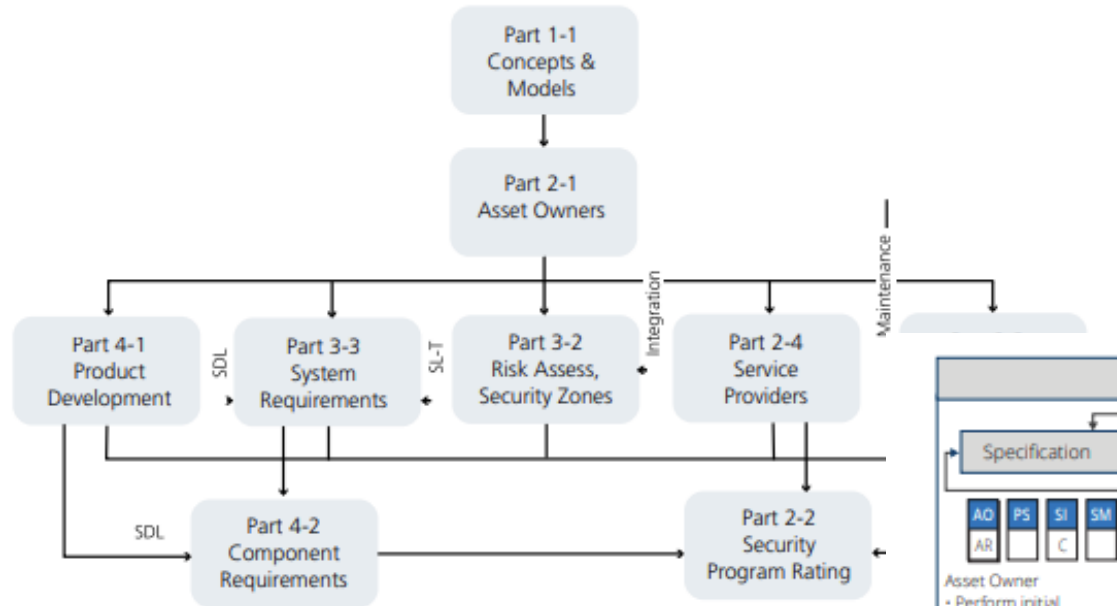
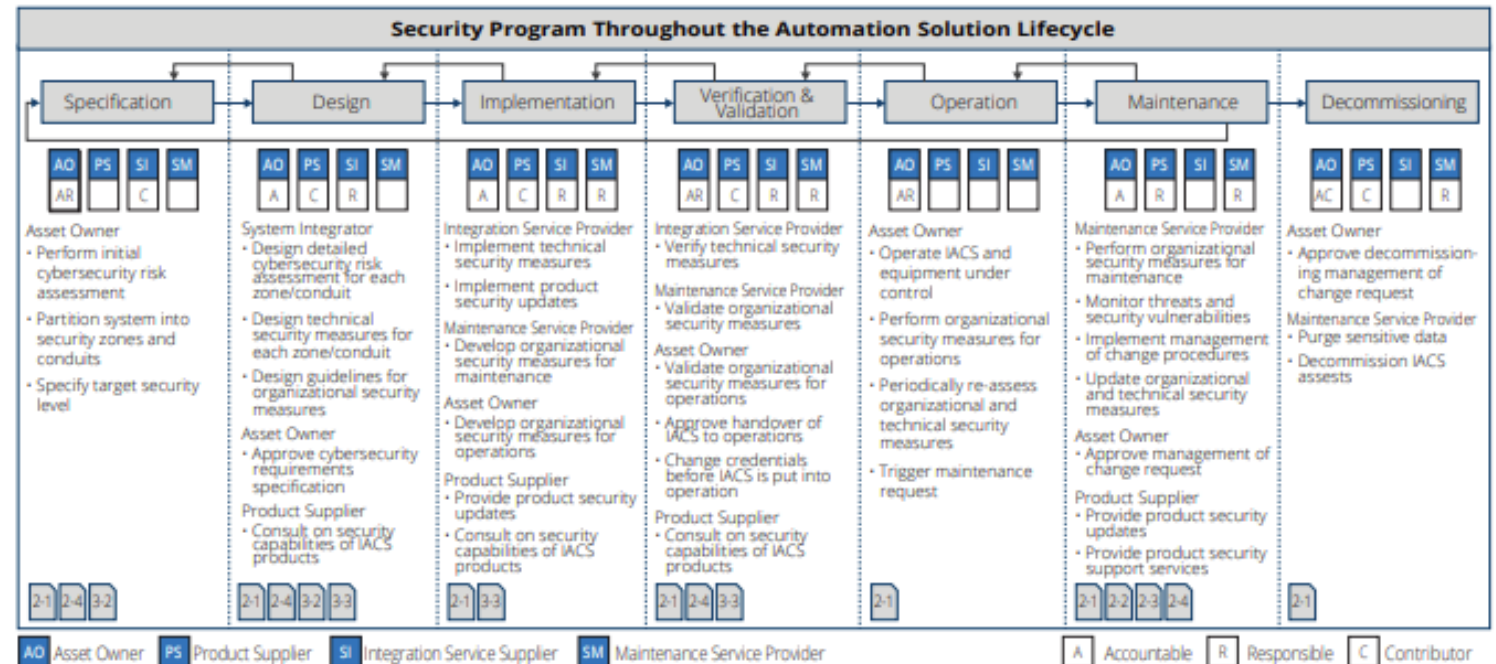


Figure 5: ISA/IEC 62443 Standards – Hierarchical View



Roles and Lifecycle View

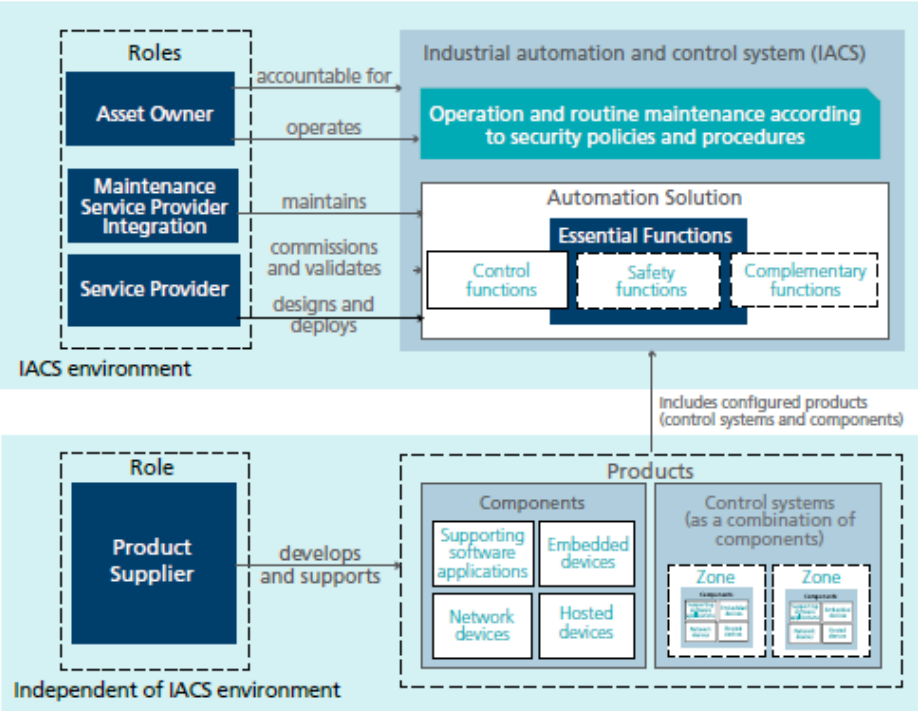


Figure 4: Roles, Products, Automation Solution, and IACS

Product Development Lifecycle	Automation Solution Lifecycle	
	Integration	Operation and Maintenance
Part 1-1: Concepts and Models		
Part 2-1: IACS requirements for Asset Owners		
Part 2-2: IACS Security Program Rating		
Part 2-3: IACS Patch management		
Part 2-4: Security program requirements for IACS service providers		
Part 3-2: Security risk assessment, system partitioning, and security levels		
Part 3-3: System security requirements and Security levels		
Part 4-1: Product development lifecycle		
Part 4-2: Technical security requirements for IACS components		

Figure 6: ISA/IEC 62443 Standards - Lifecycle View

AS IEC 62443

- In June 2025 Standards Australia adopted the ISA/IEC 62443 Standard Series as an Australian standard
- *“These standards are modular and role-based, allowing users to select only the parts relevant to their responsibilities or the stage of the system lifecycle they’re working in. They are designed for asset owners, service providers, and product suppliers, and they align with local regulatory requirements—making implementation practical and effective across sectors.”*

62443 Part 1-1 – Concepts and Models

- Definitions (e.g. What is an asset)
- Defines an asset model taxonomy
- Defines a model for Security
- Zones and Conduits
- Defines Security Levels (Target, Achieve, Capability)
- Defines Policies and Procedures Requirements
- and more ...

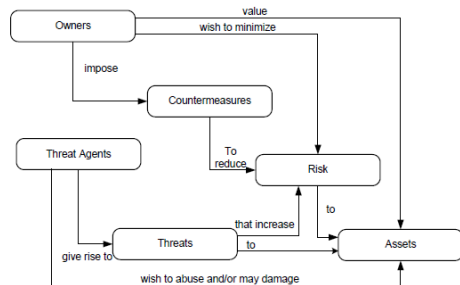


Figure 2 – Context Element Relationships

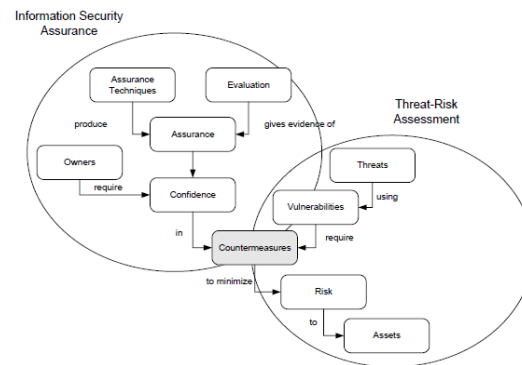


Figure 3 – Context Model

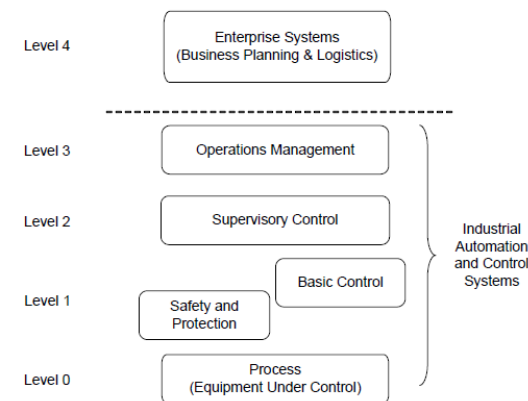


Figure 12 – Reference Model for ISA99 Standards

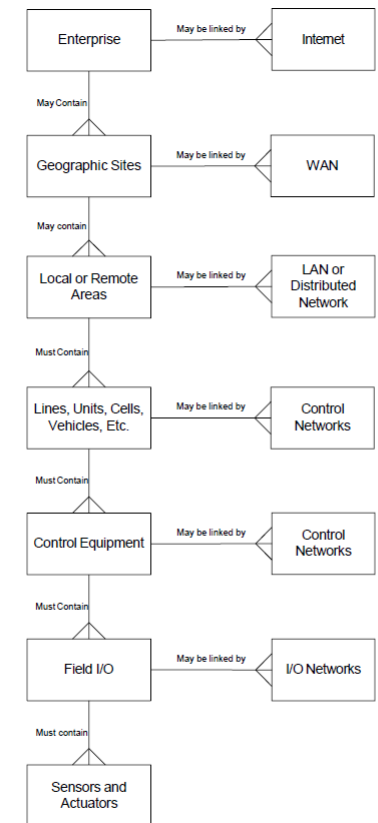
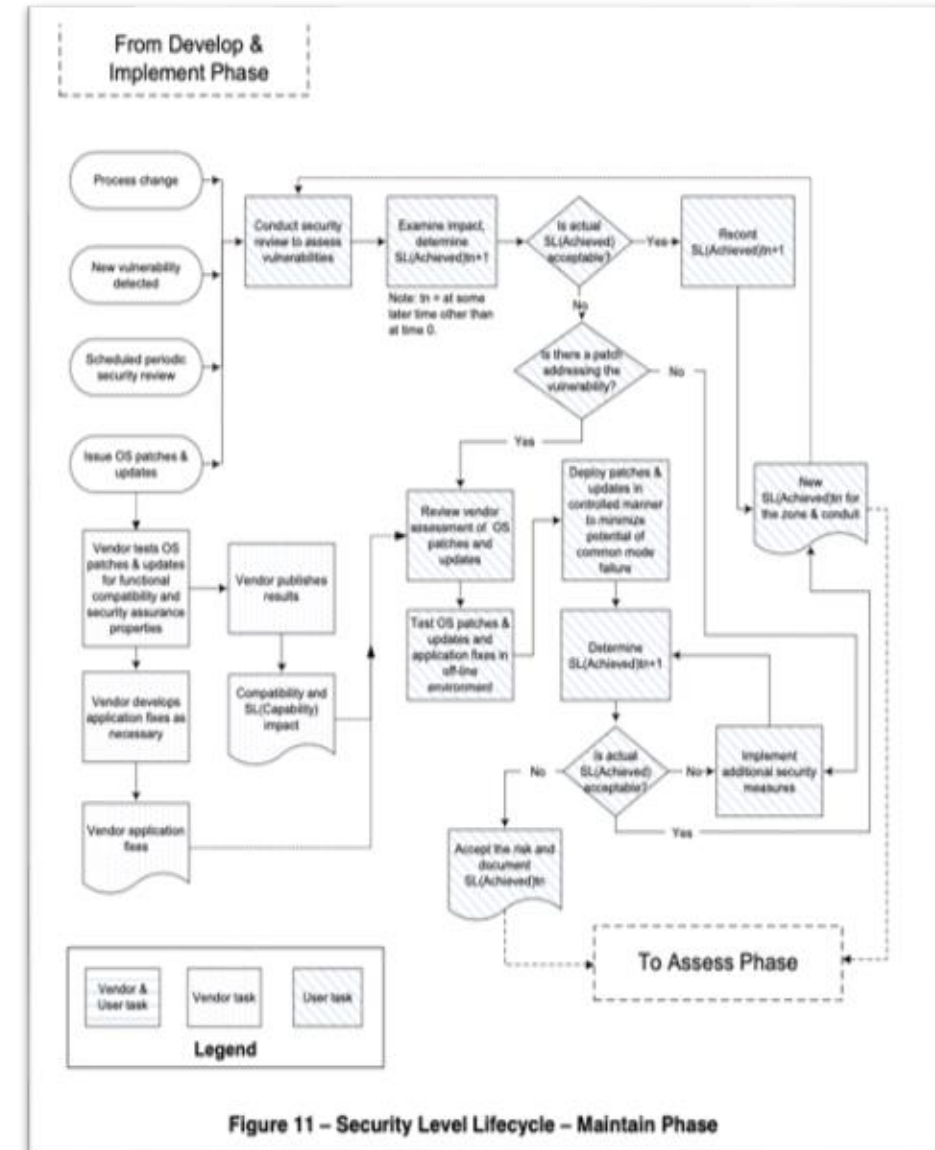
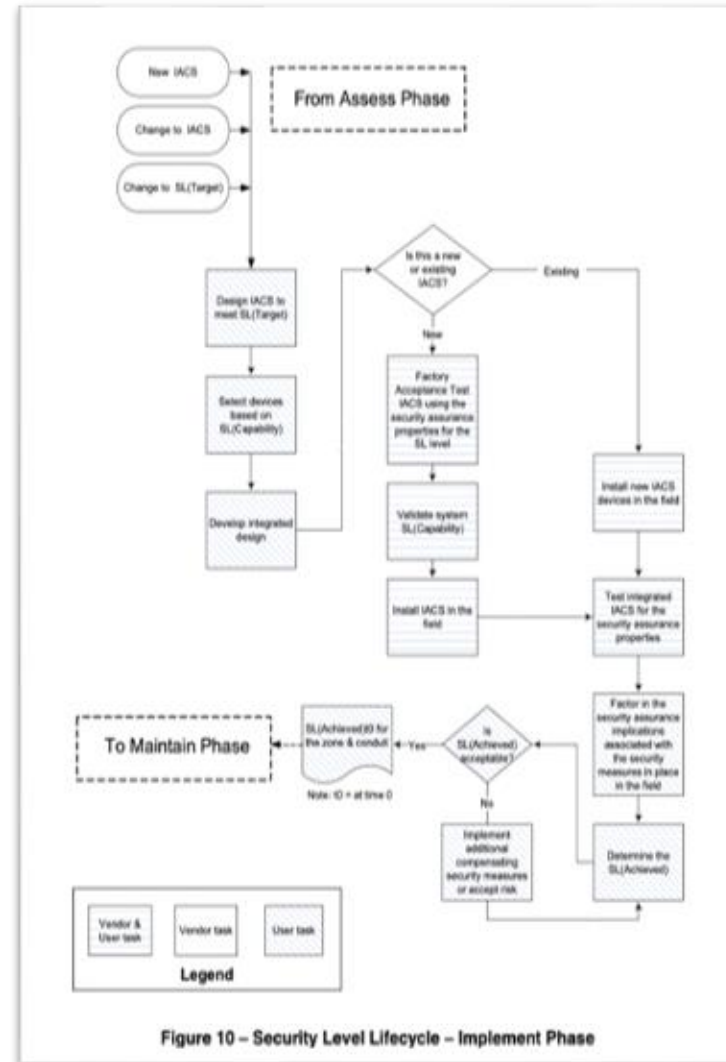
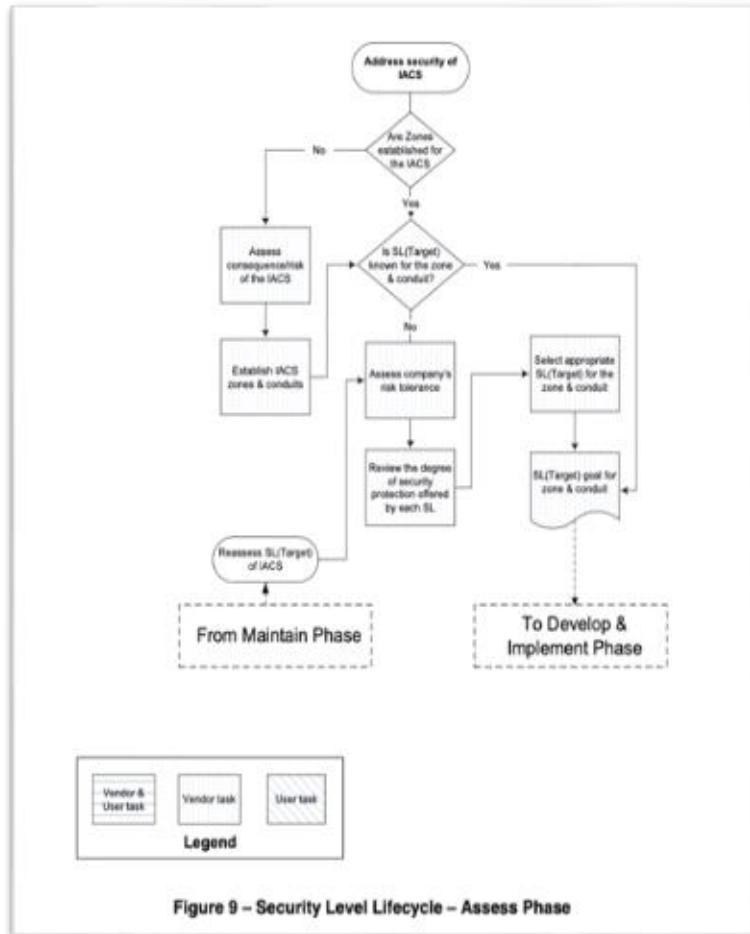


Figure 14 – Process Manufacturing Asset Model Example

Assess, Design & Implement, Operate & Maintain



Zone and Conduit Definitions

Zone

Grouping of logical or physical assets based upon risk or other criteria, such as criticality of assets, operational function, physical or logical location, required access (For example, least privilege principles) or responsible organisation

Conduit

Logical grouping of communication channels that share a common security requirements connecting two or more zones

Channel

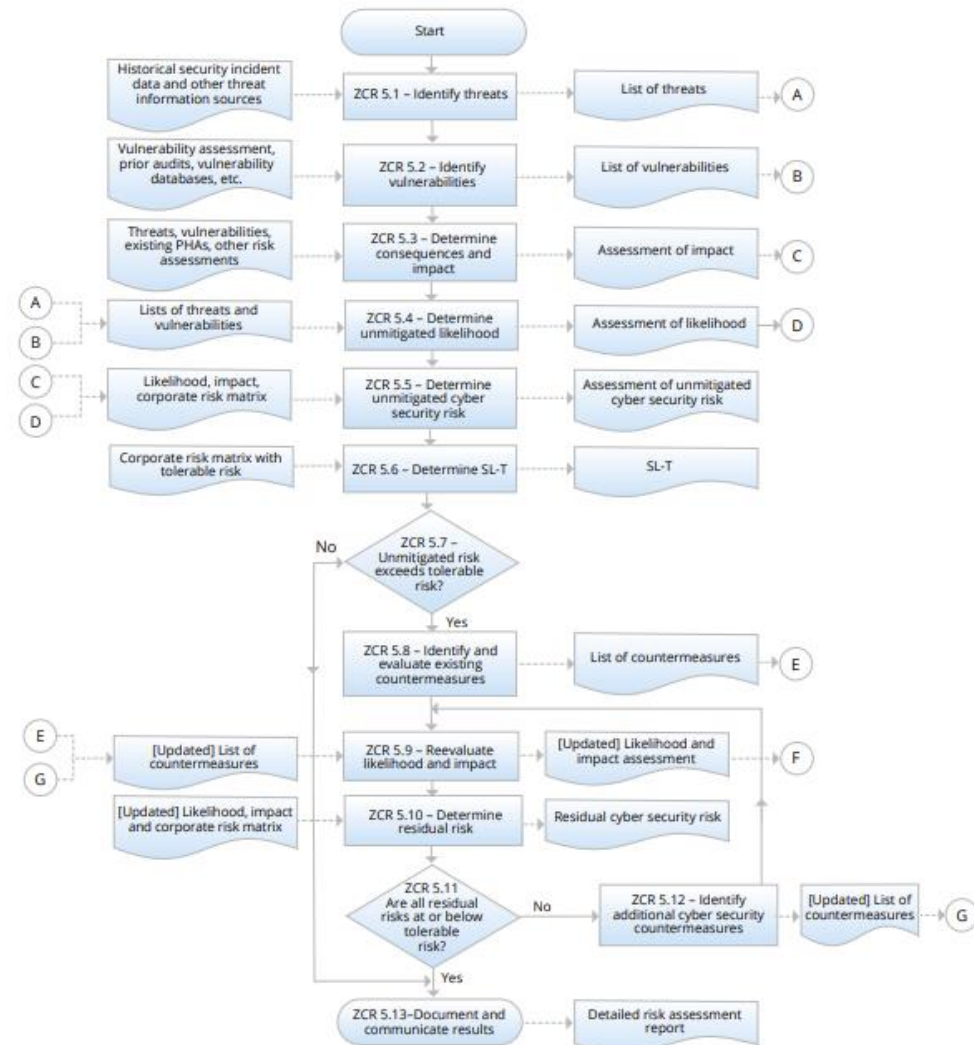
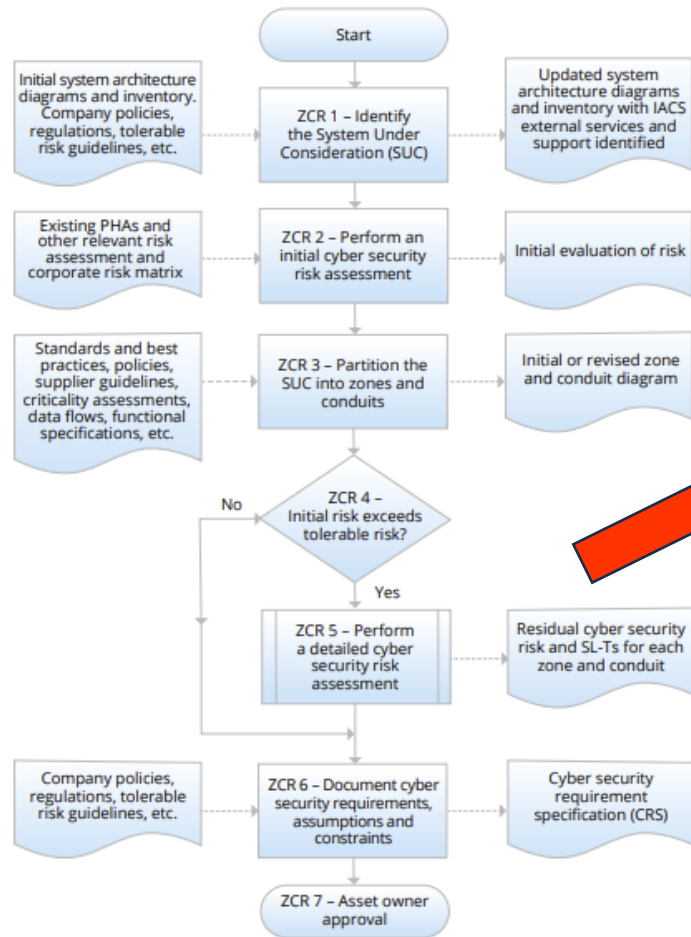
Specific logical or physical communication link between assets



Applying 62443 to your Project

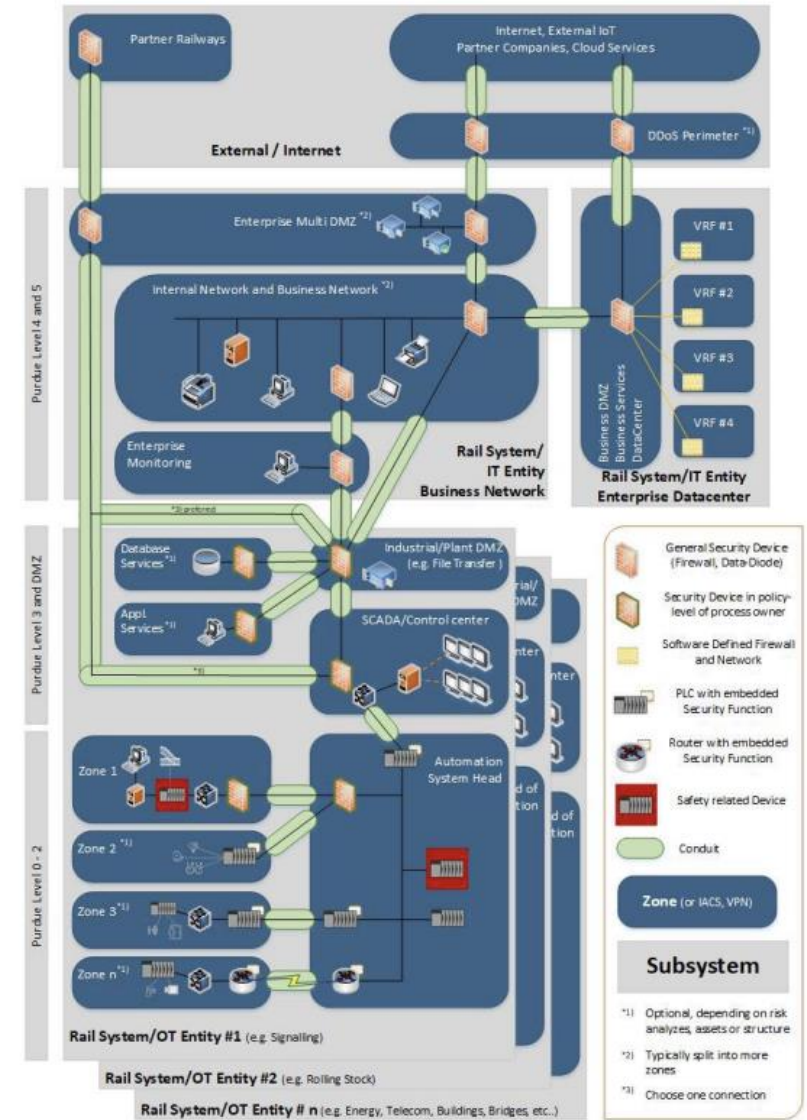
Using Part 3-2 and Part 3-3

Part 3-2 – Risk Process on a page



Partitioning the SuC

- ZCR 3.1 Establish Zones and Conduits
- ZCR 3.2 Separate business and IACS assets
- ZCR 3.3 Separate Safety related assets
- ZCR 3.4 Separate temporarily connected devices
- ZCR 3.5 Separate wireless devices
- ZCR 3.6 Separate devices connected via external networks



Security Level Definitions

- **Target (SL-T)** are the desired level of security for a particular Automation Solution. They are determined as the result of the Risk Assessment process (Part 3-2) and are documented in the Cybersecurity Requirements Specification. SL-T are used to select products and additional countermeasures during the Integration phase of the IACS lifecycle
 - **Capability (SL-C)** are the security levels that systems or Components can provide when properly configured. These levels state that a particular system or Component is capable of meeting the SL-T natively without additional compensating countermeasures.
 - **Achieved (SL-A)** are the actual levels of security for a particular Automation Solution. These are measured after the Automation Solution is commissioned and in operation.
- **SL-1** Prevent the unauthorized disclosure of information **via eavesdropping or casual exposure**
 - **SL-2** Prevent the unauthorized disclosure of information to an entity actively searching for it **using simple means with low resources, generic skills, and low motivation**
 - **SL-3** Prevent the unauthorized disclosure of information to an entity actively searching for it using sophisticated means with **moderate resources, IACS-specific skills, and moderate motivation**
 - **SL-4** Prevent the unauthorized disclosure of information to an entity actively searching for it using **sophisticated means with extended resources, IACS-specific skills, and high motivation**

Example 62443 Risk Workbook

		Threat Scenario		Consequence															
	Threat Source	Threat Action	Vulnerabilities	Consequence Description	Impact								SL-T	Countermeasures	MTL	Risk	Recommendations	ATL	Risk
Zone					S	E	F	R	Max	UTL	Risk								
Process Control Zone	Authorised Personnel	Inserts USB into Operation Station (OS) with General Malware	* OS Computers are in the Control Room * USB Ports are not blocked or disabled * Autorun not disabled * No Antivirus	* Denial of service on operator station that spreads to all OS on PCN * All OS and Servers need to be rebuilt * 24-72 hours downtime * Rework batch * Supply chain impact	1	1	2	3	3	5	15	2	* Policies and Procedures	5	15	* Disable unused USB prots (E.g. GPO, Registry, SEP, etc) * Relocate OS computers to the server room and KVM to Control Room * Segment the Tag & Batch servers and the EWS from the PCN and Control Lan (e.g. Elimiate all Dual Homed Computers) * Install and maintain Antivirus * Stricter enforcement of policies * Upgrade OS and application software to supported version	2	6	
		Inserts USB into Operator Station with targeted malware	* OS Computers are in the Control Room * USB Ports are not blocked or disabled * Autorun not disabled * No Antivirus	* Loss of control with potential compromise of the safety of the process * Runaway reaction leading to explosion	5	5	5	5	5	2	10	1	* Policies and Procedures	2	10	* Disable unused USB prots (E.g. GPO, Registry, SEP, etc) * Relocate OS computers to the server room and KVM to Control Room * Segment the Tag & Batch servers and the EWS from the PCN and Control Lan (e.g. Elimiate all Dual Homed Computers) * Install and maintain Antivirus * Stricter enforcement of policies * Upgrade OS and application software to supported version	1	5	
		Plugs laptop infected with general malware into the Control LAN	* Unused ports on the Control LAN switch are enabled * No Policy governing use of Laptops * No antivirus on Tag and Batch servers * Lack of segmentation allows for propagation	* Denial of service on operator station that spreads to all OS on PCN * All OS and Servers need to be rebuilt * 24-72 hours downtime * Rework batch * Supply chain impact	1	1	2	3	3	4	12	2	* Laptops are running a supported OS, are patched and running Anti-Virus	4	12	* Develop policies to prohibit use of laptops on Control LAN * Block unused porst on Control LAN Switch * Segment the Tag & Batch servers and EWS from the PCN and Control LAN (e.g. eliminate all dual-homed computers) * Install and Maintain Antivirus	1	3	
		Plugs laptop infected with targeted malware into the Control LAN	* Unused ports on the Control LAN switch are enabled * No Policy governing use of Laptops * No antivirus on Tag and Batch servers * Lack of segmentation allows for propagation	* Loss of control with potential compromise of the safety of the process * Runaway reaction leading to explosion	5	5	5	5	5	2	10	1		2	10	* Develop policies to prohibit use of laptops on Control LAN * Block unused porst on Control LAN Switch * Segment the Tag & Batch servers and EWS from the PCN and Control LAN (e.g. eliminate all dual-homed computers) * Install and Maintain Antivirus	1	5	
		Engineer remotes into the EWS from the Plant Business Zone using VNC and makes changes without knowledge of current process conditions	* By default VNC credentials are in 'clear text' * VNC file transfer capabilities	* Possible process upset or modification leading to loss of batch	1	1	2	1	2	4	8	1		4	8	* Develop and enforce MoC Process * Eliminate VNC	1	2	

Where:

UTL – Unmitigated Threat Likelihood

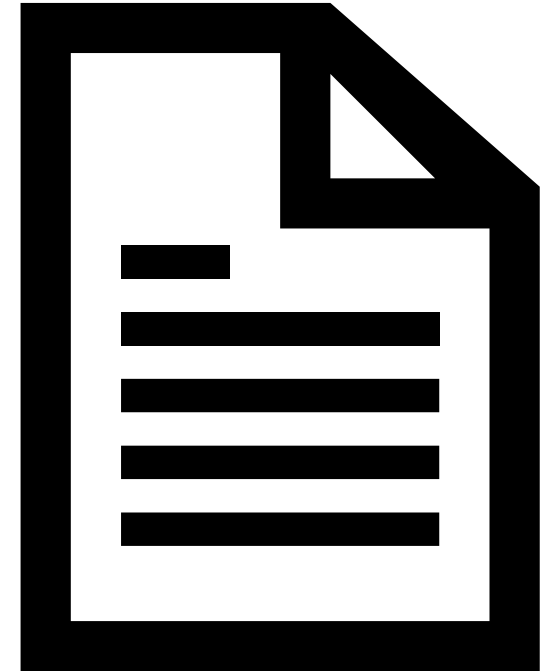
SL-T Security Level Target

MTL – Mitigated Threat Likelihood

ATL – Adjusted Threat Likelihood

Cyber Security Requirements Specification (CRS)

- ZCR 6.2 SuC Description
- ZCR 6.3 Zone and Conduit drawings
- ZCR 6.4 Zone and Conduit Characteristics
- ZCR 6.5 Operating environment assumptions
- ZCR 6.6 Threat environment
- ZCR 6.7 Organisational security policies
- ZCR 6.8 Tolerable Risk
- ZCR 6.9 Regulatory requirements



Part 3-3 Foundational Requirement Counts

- FR 1 – Identification and Authentication Control (IAC)
- FR 2 – Use Control (UC)
- FR 3 – System Integrity (SI)
- FR 4 – Data Confidentiality (DC)
- FR 5 – Restricted Data Flow (RDF)
- FR 6 – Timely Response to Events (TRE)
- FR 7 – Resource Availability (RA)

Foundational Requirement	Count SL-1	Count SL-2	Count SL-3	Count SL-4	Total
IAC	10	6	6	2	24
UC	8	4	9	3	24
SI	6	4	6	3	19
DC	2	2	1	1	6
RDF	4	2	4	1	11
TRE	1	1	1	-	3
RA	7	3	3	-	13
Total	38	22	30	10	100

Example 3-3

SRs and REs		SL 1	SL 2	SL 3	SL 4
FR 5 – Restricted data flow (RDE)					
SR 5.1 – Network segmentation		9.3 SR 5.1 – Network segmentation			
RE (1) Physical network s		9.3.1 Requirement			
RE (2) Independence from networks		The control system shall provide the capability to logically segment control system networks from non-control system networks and to logically segment critical control system networks from other control system networks.			
RE (3) Logical and physical networks		9.3.2 Rationale and supplemental guidance			
SR 5.2 – Zone boundary protection		Network segmentation is used by organizations for a variety of purposes, including cyber security. The main reasons for segmenting networks are to reduce the exposure, or ingress, of network traffic into a control system and reduce the spread, or egress, of network traffic from a control system. This improves overall system response and reliability as well as provides a measure of cyber security protection. It also allows different network segments within the control system, including critical control systems and safety-related systems, to be segmented from other systems for an additional level of protection.			
RE (1) Deny by default, a		Access from the control system to the World Wide Web should be clearly justified based on control system operational requirements			
RE (2) Island mode		9.3.3 Requirement enhancements			
RE (3) Fail close		(1) Physical network segmentation			
		The control system shall provide the capability to physically segment control system networks from non-control system networks and to physically segment critical control system networks from non-critical control system networks.			
		(2) Independence from non-control system networks			
		The control system shall have the capability to provide network services to control system networks, critical or otherwise, without a connection to non-control system networks.			
		(3) Logical and physical isolation of critical networks			
		The control system shall provide the capability to logically and physically isolate critical control system networks from non-critical control system networks.			

All of FR5 – Restricted Data Flow

- SR 5.1 – Network segmentation (**SL-1**)
 - SR 5.1 RE 1 – Physical network segmentation (**SL-2**)
 - SR 5.1 RE 2 – Independence from non-control system networks (**SL-3**)
 - SR 5.1 RE 3 – Logical and physical isolation of critical networks (**SL-4**)
- SR 5.2 – Zone boundary protection (**SL-1**)
 - SR 5.2 RE 1 – Deny by default, allow by exception (**SL-2**)
 - SR 5.2 RE 2 – Island mode (**SL-3**)
 - SR 5.2 RE 3 – Fail close (**SL-3**)
- SR 5.3 – General purpose person-to-person communication restrictions (**SL-1**)
 - SR 5.3 RE 1 – Prohibit all general purpose person-to-person communications (**SL-3**)
- SR 5.4 – Application partitioning (**SL-1**)

Cyber Security Design Specification (CDS)

- This document captures design rationale and can be used to articulate the specification and plan to implement controls
- Consider the 5 D's for identified threats
 - Deter
 - Detect
 - Delay
 - Deny
 - Degrade
 - Deceive

Threat Scenario	Potential Mitigations				
	Deter	Detect	Delay	Deny	Defeat
Threat 1	Policy	IDS	Account lockout delays	AV	AV
Threat 2	...	...	...	...	...

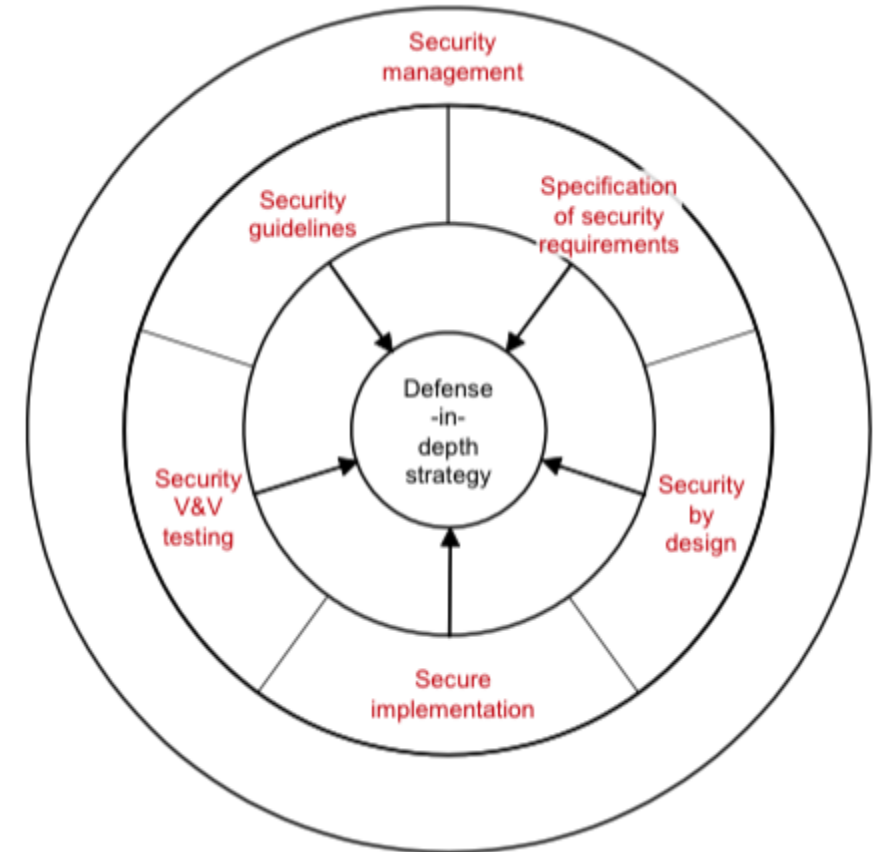


Building secure components

Using Part 4-1 and Part 4-2

Part 4-1 – Secure Product Development Lifecycle Requirements

- Primary goal of the framework to produce a secure-by-design, defense-in-depth approach to designing, building, maintaining and retiring products in use in Industrial Automation and Control Systems
- Defines requirements per Practice:
 - Practice 1 - Security Management
 - Practice 2 - Specification of Security Requirements
 - Practice 3 - Secure by Design
 - Practice 4 - Secure Implementation
 - Practice 5 - Security Verification and Validation testing activities
 - Practice 6 - Management of security-related issues
 - Practice 7 - Security Update Management
 - Practice 8 - Security Guidance



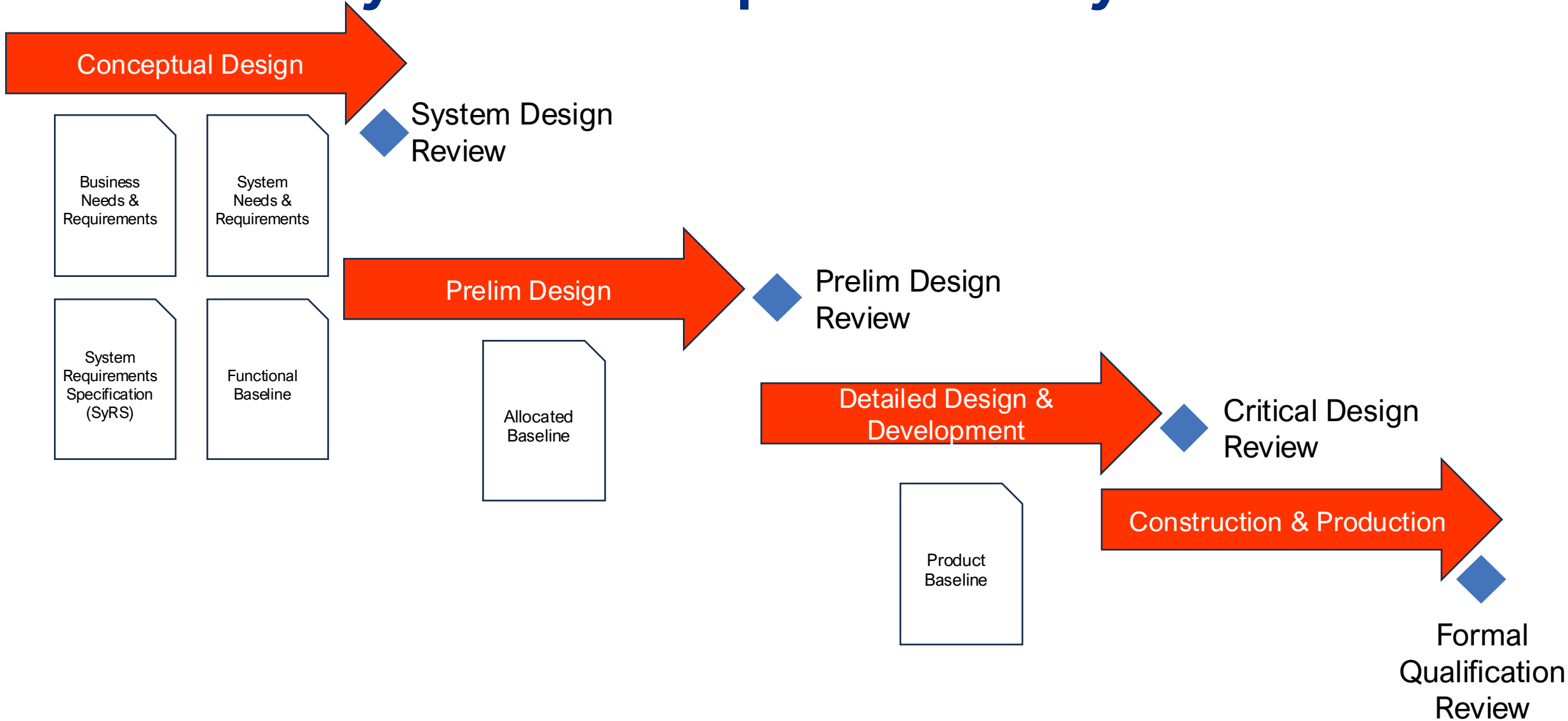
Part 4-2 – Technical Security requirements for IACS components

- Provides Component Requirements (CRs) to meet Security Level Capabilities for Foundational Requirements from Part 3-3 along with Rationale and Guidance
- Defines four component types:
 - Software Application
 - Embedded Device
 - Host Device
 - Network Device
- Defines representative Device Categories in Appendix A

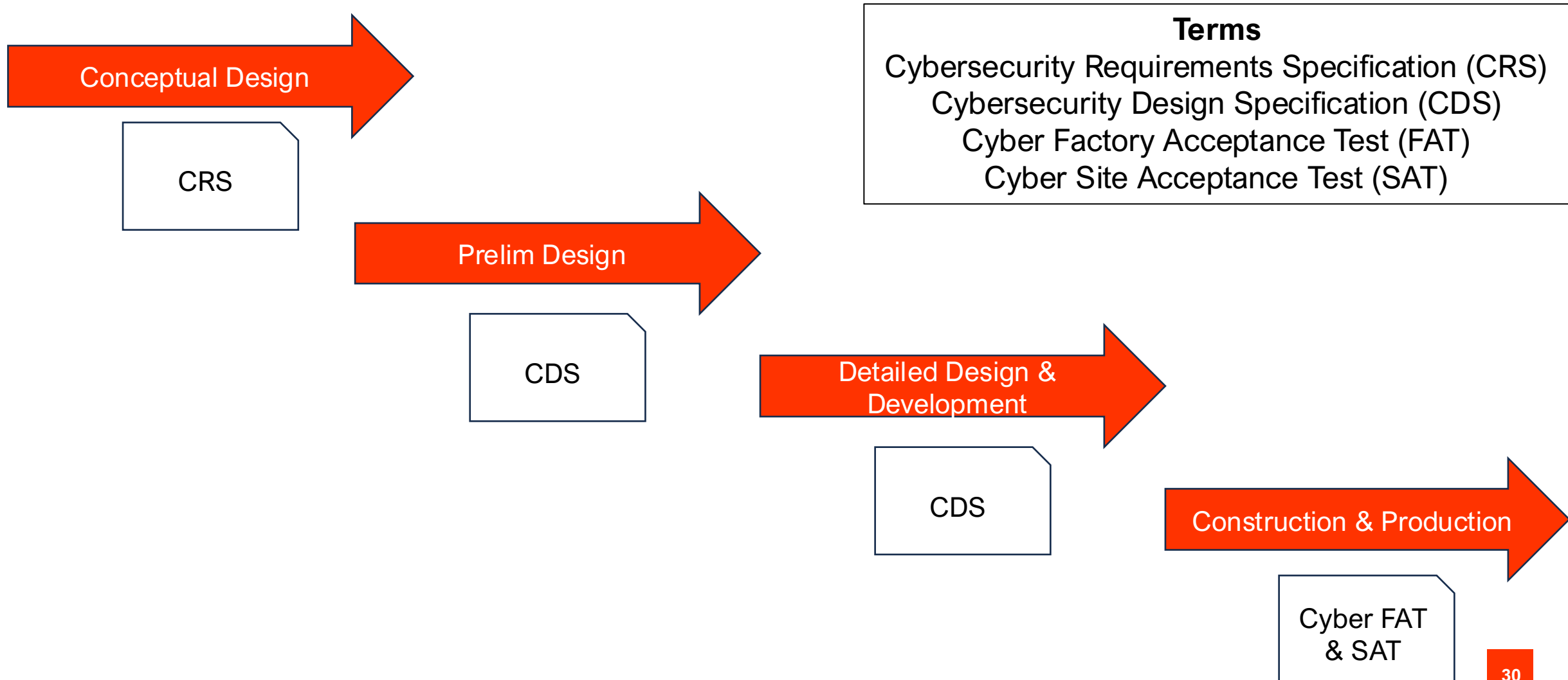


Aligning ISA/IEC 62443 with the System Engineering Lifecycle

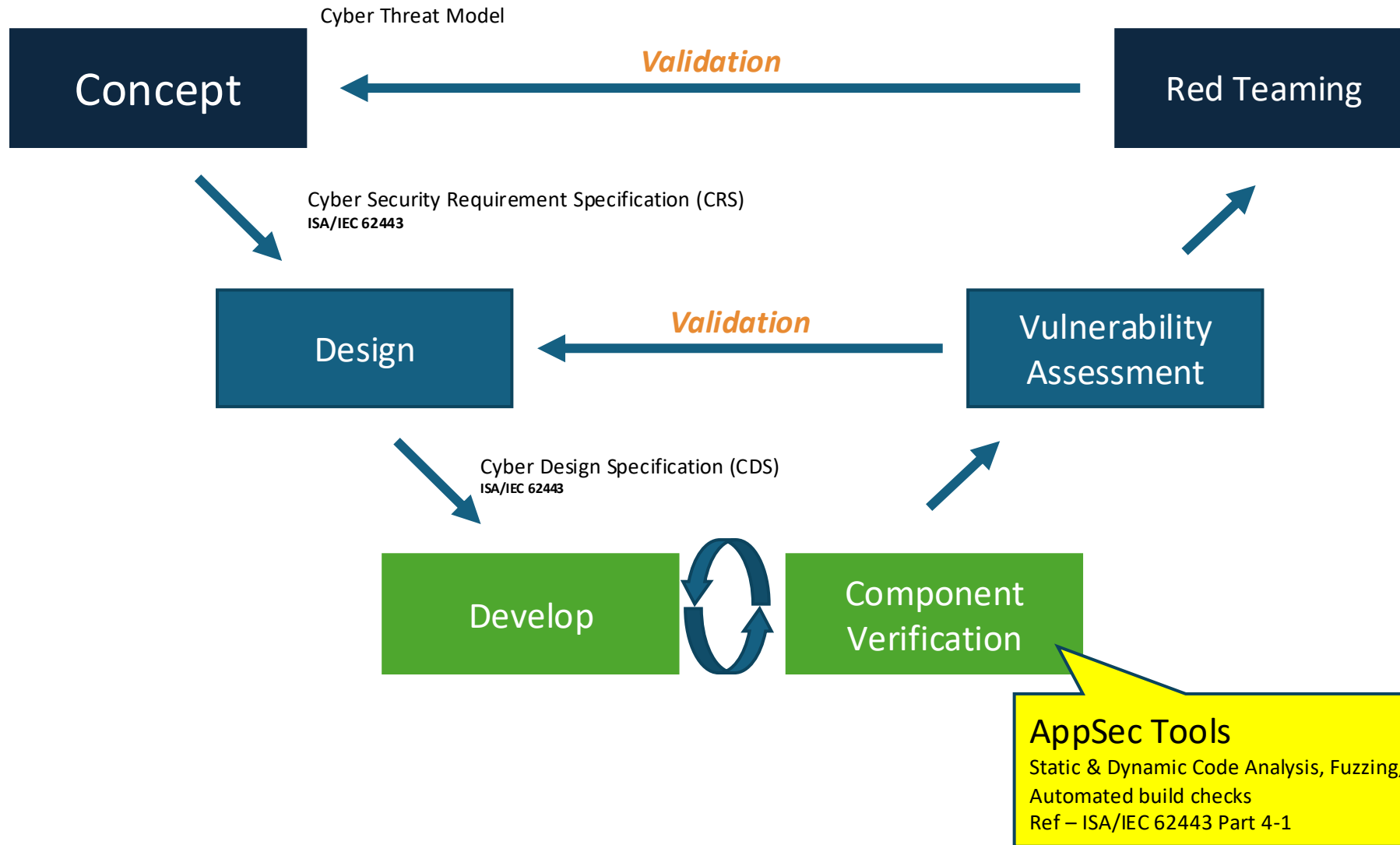
Reference System Development Life Cycle



Alignment of System Development Lifecycle and 62443 Documents

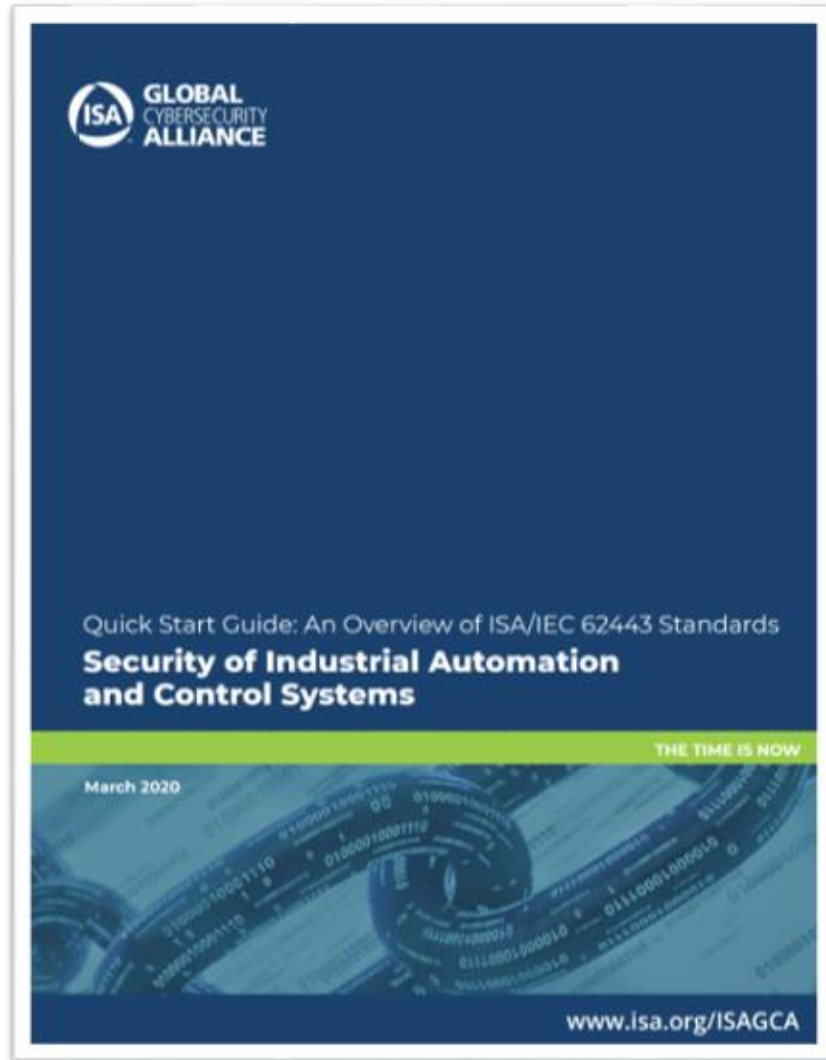


Cyber V Model

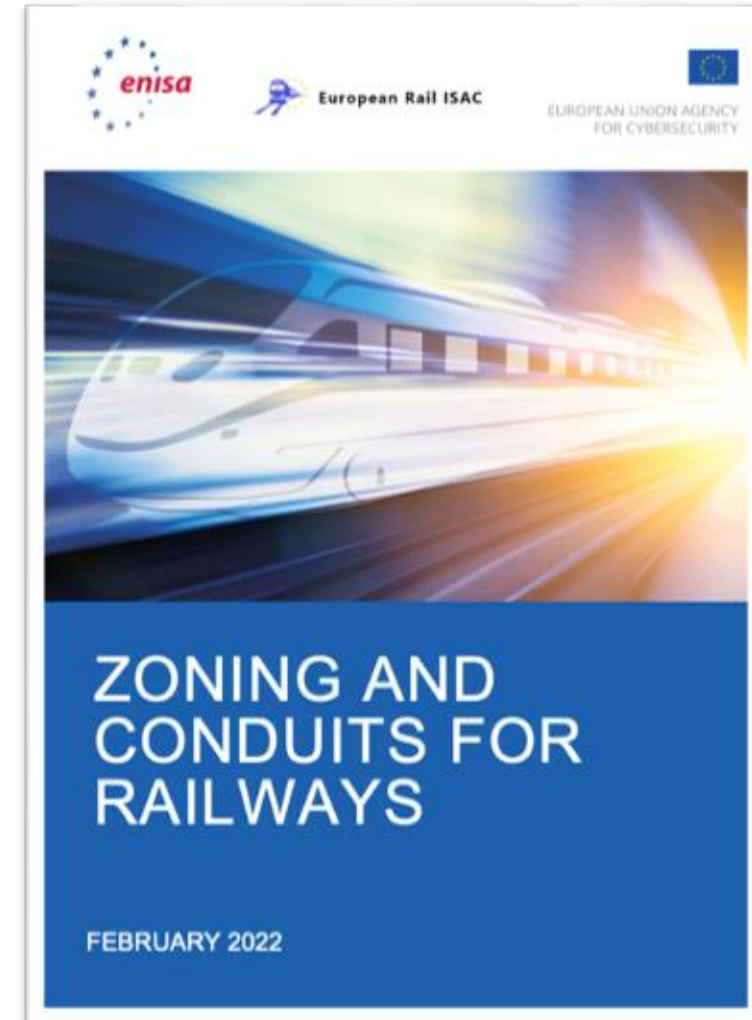




Further Resources



<https://gca.isa.org/hubfs/ISAGCA%20Quick%20Start%20Guide%20FINAL.pdf>



<https://www.enisa.europa.eu/publications/zoning-and-conduits-for-railways>

Effective ICS Cybersecurity Using the IEC 62443 Standard

Jason Dely

Copyright SANS Institute 2021. Author Retains Full Rights.
This paper was published by SANS Institute. Reposting is not permitted without express written permission.

<https://www.sans.org/white-papers/39990/>

Managing ICS Security with IEC 62443

(Companion piece to "Effective ICS Cybersecurity Using the IEC 62443 Standard")

Written by **Jason Dely**

November 2020

Sponsored by:

Fortinet

Standards give us a common vocabulary to help us understand a particular subject as well as solve a particular problem. Similarly, cybersecurity standards direct and guide organizations to meet their security goals. Managers looking to meet their companies' security goals can accelerate their knowledge of the problem and achieve those goals by leveraging the advice of the industry experts who authored the standards.

Following the IEC 62443 series of standards (hereafter in this paper referred to collectively as "the Standard"), also known as *IACS*, can help strategically mature an organization's industrial controls systems (ICS), or, as the Standard calls them, *industrial automation and control systems*. The Standard provides all sectors with a common framework to manage and mitigate security vulnerabilities in industrial automation control systems. Most industrial customers are only interested in what their sector is doing, but the IEC 62443 series of standards are representative of *all* sectors and should therefore be consumed by individual sectors.

In a companion whitepaper, "Effective ICS Cybersecurity Using the IEC 62443 Standard,"¹ we looked at the structure and purpose of IEC 62443 and how Fortinet products can assist in implementing the security requirements stated within the Standard. In this paper, we examine how to use the Standard to strategically reduce your ICS cybersecurity risk.

¹ SANS Institute, Effective ICS Cybersecurity Using the IEC 62443 Standard, November 2019, www.sans.org/reading-room/whitepapers/analyst/effective-ics-cybersecurity-iec-62443-standard-39960 [Registration required.]

<https://www.sans.org/white-papers/39990/>



IMPLEMENTING IEC 62443

A Pragmatic Approach to Cybersecurity

David G. Gunter
Michael D. Medoff
Patrick C. O'Brien



<https://www.amazon.com.au/Implementing-IEC-62443-Pragmatic-Cybersecurity/dp/1934977179>

<https://www.isa.org/certification/certificate-programs/isa-iec-62443-cybersecurity-certificate-program>

Questions? Thank you!



<https://linkedin.com/in/blargeau>



bruce@blarge.io



<https://blarge.io>